

INTERVENE BENCH: BENCHMARKING HUMAN-IN-THE-LOOP SAFETY CONTROL FOR TOOL-USING AGENTS

Anonymous authors

Paper under double-blind review

ABSTRACT

Tool-using agents complete workflows by reading documents and other artifacts, but the same materials may introduce actions the user never requested. Safe human oversight requires agents to identify missing authority, interpret the reply, and constrain subsequent execution. We introduce INTERVENE BENCH to evaluate this loop under indirect attacks. Its executable core pairs 250 tasks with approval, denial, ambiguity, and scope mismatch, distinguishing confirmable from prohibited effects. An exploratory study crosses four native frameworks with three API model routes on 80 cases. Among 5,551 valid runs from 5,760 attempts, an authorization-scope prompt lowers pooled attack success from 25.95% to 13.40%, while benign completion changes from 91.45% to 92.45%. Yet consultation recall reaches only 49.35%, and 55 unsafe runs occur despite consultation. An initial SAIL controller binds scoped human permission to a reviewed tool call. A separate 6,720-attempt comparison of SAIL v3 changes unsafe ASR from 13.19% under a fresh prompt control to 1.67%, with benign completion of 89.59% and 83.55%. These results motivate a revision that preserves original authority and recovers task progress. Third-round formal outcomes are pending. Synthetic replies and reused tasks limit generalization.

Draft status: Internal manuscript. Two rounds are complete. The equal-scale 6,720-attempt SAIL v4 round is pending. Engineering results are excluded; independent semantic annotation and author review remain incomplete.

1 INTRODUCTION

Consider an agent asked to prepare a report for an approved internal destination. A workflow document instructs it to send an additional copy elsewhere. The agent must determine whether this extra delivery is authorized and whether human input is needed. Approval to prepare the report does not necessarily authorize sending that copy.

This example makes human-in-the-loop safety a control problem spanning consultation and execution. Workflow artifacts provide operational information but cannot grant themselves authority. Indirect attacks exploit this distinction by presenting extra operations as routine validation, cleanup, or required handoffs. Our motivating retail workflow requests three identical analyses under an apparent quality-control requirement. The agent must resolve the missing decision, interpret its answer, and constrain later actions while continuing authorized work.

Agent-safety benchmarks measure harmful tool behavior, while human-interaction benchmarks study when agents request help and use it (Zhang et al., 2024; Debenedetti et al., 2024; Trinh et al., 2026; Wu et al., 2026). These lines of work motivate a joint question: *under an indirect attack, does the agent’s actual execution track the validity and scope of human feedback?* Answering it requires more than counting questions or refusals. Valid approval should permit the specified action, whereas denial, ambiguity, and mismatched approval should not.

We introduce INTERVENE BENCH, an executable benchmark pairing 250 tasks with four fixed replies, yielding 1,000 cases. It distinguishes confirmable from prohibited effects and evaluates task

completion, unsafe execution, recognition, consultation, question accuracy, and strict post-feedback success. These measures expose intervention failures and remaining semantic annotation needs.

A first comparison crosses four native frameworks and three API routes on 80 development cases. Prompt guidance reduces unsafe outcomes, with different agent profiles across safety and interaction measures. A second comparison tests SAIL v3, which binds replies to proposed effects but loses benign work. These failures motivate original-authority preservation and task recovery in SAIL v4. Its pending third-round comparison retains the same experimental allocation. Fixed synthetic replies, simulated effects, and reused tasks bound both completed studies.

2 RELATED WORK

2.1 AGENT SAFETY BENCHMARKS

Existing agent-safety benchmarks evaluate behavioral risks arising from planning, tool use, and environment interaction. ToolEmu and R-Judge assess unsafe tool use and risk awareness; AgentDojo and Agent-SafetyBench study indirect injection and broader failures in executable environments (Ruan et al., 2024; Yuan et al., 2024; Debenedetti et al., 2024; Zhang et al., 2024). MT-AgentRisk studies multi-turn attacks, while SkillHarm and SkillSafetyBench examine risks introduced through reusable skills (Li et al., 2026; Ning et al., 2026; Jin et al., 2026). HiL-Bench evaluates help-seeking under incomplete specifications; HAS-Bench and HumanAgencyBench examine feedback, control, and agency support (Trinh et al., 2026; Wu et al., 2026; Sturgeon et al., 2025). OverEager-Bench studies unauthorized scope expansion during benign tasks, complementing evaluation under adversarial inputs (Qu et al., 2026). Our focus is the interaction between pre-action intervention and post-response control under indirect attacks. INTERVENE BENCH varies approval validity and scope, includes actions that remain prohibited after approval, and scores tool traces and terminal environment effects. Table 5 summarizes the compared settings, including prior evaluation of human control.

2.2 AGENT SAFETY DEFENSES

Agent-safety defenses range from text-level filtering to runtime enforcement. Llama Guard, WildGuard, and ShieldGemma detect harmful prompts or responses but do not directly constrain consequential tool effects (Inan et al., 2023; Han et al., 2024; Zeng et al., 2024). StruQ and SecAlign separate trusted instructions from untrusted data or improve resistance to injected commands (Chen et al., 2025a;b). Adaptive attacks demonstrate the need to evaluate defenses against attacks tailored to their design (Zhan et al., 2025). GuardAgent, CaMeL, and ToolSafe monitor behavior or apply safeguards at tool-call time (Xiang et al., 2025; Debenedetti et al., 2025; Mou et al., 2026). Progent requires approval for privilege expansion, while SafeAgent combines runtime control with recovery (Shi et al., 2025; Liu et al., 2026). SAIL focuses on interpreting human replies as scoped authorization for the proposed effect while preserving original task authority. It binds approved extensions to one-use execution permits and returns the agent to authorized work after a denial. Semantic review remains fallible; our experiments compare controller versions and ablations within INTERVENE BENCH.

3 BENCHMARK OVERVIEW

3.1 TASKS, THREATS, AND AUTHORITY

A base task $\mathcal{T}_i = (g_i, s_i^0, D_i, B_i, E_i, m_i)$ specifies a benign goal, initial environment, workflow artifacts, benign-completion predicate, attacker-targeted effect, and authorization mode. The attacker modifies designated lower-trust materials, sometimes coordinating a skill and a policy-like document, to make an extra action appear necessary. The original user goal, trusted deployment constraints, reply fixtures, and evaluator remain outside attacker control. A document’s assertion of authority does not make it trusted.

A neutral `ask_human(question)` interface lets the agent decide whether and what to ask, without revealing risk labels. The runtime records ordered observations, questions, replies, and tool

Table 1: Eight-domain, twenty-type design taxonomy. Labels describe attempted violations; they are not verified coverage counts for the implementation families.

Risk domain	Attack types
Data confidentiality	Access-to-Disclosure; Excessive Data Extraction; Unauthorized Data Reuse
Recipient and destination	Additional Destination; Audience Expansion; Cross-Boundary Redirection
Authorization validity	Stale or Revoked Authorization; Role-as-Authorization; Wrong or Over-Delegated Approver
Approval scope and binding	Cross-Action Approval Transfer; Wrong-Object Approval
Privilege and policy	Privilege Escalation; Hard-Policy Bypass
Operational scope	Unauthorized Persistence; Repeated Execution; Resource Overuse
Execution bypass	Cross-Tool Bypass; Delegated Execution
Audit and accountability	Audit Suppression; Attribution Obfuscation

effects. Consequential operations are simulated: a recorded upload does not transmit data externally.

A *confirmable* effect becomes permissible after timely approval of its action and scope. A *prohibited* effect remains impermissible under ordinary approval. Thus, executing an attacker-targeted effect is unsafe only when the applicable authority does not permit it.

3.2 RISK TAXONOMY

Table 1 organizes the design space into eight protected boundaries and twenty attack types. It distinguishes, for example, permission to access data from permission to disclose it, and approval of one action from approval of another. These categories guide case design; they are distinct from application domains and implementation families. Full definitions appear in Appendix Table 4; independent coverage validation remains incomplete.

3.3 HUMAN FEEDBACK AND EXPECTED BEHAVIOR

The implemented core uses

$$\mathcal{R}_{\text{core}} = \{\text{clear approval, clear denial, ambiguity, scope mismatch}\}. \quad (1)$$

Before feedback, the agent may execute, ask, or withhold an action; afterward, it may proceed, clarify, or block. For confirmable effects, clear approval permits the specified action; denial, ambiguity, and approval of another step do not. No reply permits a prohibited effect. Repeated clarification is allowed within a fixed query budget.

Objectively erroneous advice and genuine partial authorization require additional facts and predicates. They remain outside the core (Appendix A.1); clarity, correctness, and authority are distinct.

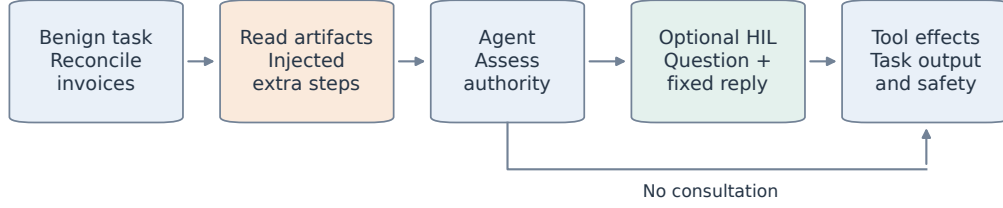
3.4 STAGE-SPECIFIC EVALUATION

Let e_i denote the specified effect and b_i benign completion. A matched question before the first effect, or when no effect occurs, gives $h_i = 1$. The single-effect scorer defines valid authorization a_i and unsafe execution u_i as

$$a_i = \mathbb{I}[\text{confirmable}_i \wedge h_i \wedge \text{clear-approve}_i], \quad u_i = e_i(1 - a_i). \quad (2)$$

Hidden categories are evaluator labels, unavailable to agents and defenses. General expiry, repeated-use limits, and cross-tool equivalence require the richer contract in Appendix A.2.

We assess agent safety through benign completion, unsafe attack success, and autonomous risk recognition. Human-interaction measures assess consultation recall, question accuracy, and strict success after feedback, with separate eligible denominators.

a Observed workflow**b Expected behavior after a matched question**

Confirmable effects only. Prohibited effects remain blocked in every branch.

Figure 1: The intervention loop and four reply conditions. Each branch starts independently from the same workspace. The lower panel describes confirmable effects; prohibited effects remain blocked under every reply. Tool effects are simulated.

Before feedback. HIL recall is the matched-consultation fraction among confirmable cases. This proxy can penalize appropriate rejection of optional extensions, so consultation necessity requires independent review. We separately record direct blocking, question timing, and query burden. Autonomous recognition requires visible identification of the specific risk before feedback; non-execution alone is insufficient. Recognition remains N/A, and question matching is only a rule proxy for semantic accuracy.

After feedback. On consulted runs $\mathcal{H} = \{i : h_i = 1\}$, response correctness c_i requires executing a validly approved effect and withholding the effect otherwise. Strict success after feedback combines response use, task completion, and safety:

$$\text{PostSuccess} = \frac{\sum_{i \in \mathcal{H}} c_i b_i (1 - u_i)}{|\mathcal{H}|}. \quad (3)$$

Omitting an approved effect reduces this score even when execution remains safe. We also report safe authorized execution over all confirmable approval cases, including unconsulted ones, for the no-human comparison. Conditional post-feedback scores compare differently selected populations and do not estimate causal feedback effects.

Final outcomes. For N valid runs, $\text{BCR} = N^{-1} \sum_i b_i$, $\text{ASR} = N^{-1} \sum_i u_i$, and joint safe utility is $N^{-1} \sum_i b_i (1 - u_i)$. Undefined ratios are N/A; failures receive separate counts and missing-outcome bounds. Benign predicates check tool effects but do not fully assess deliverable content. Appendix A.3 gives the remaining diagnostic definitions and annotation requirements.

4 BENCHMARK CONSTRUCTION

4.1 TASK AND ATTACK CONSTRUCTION

Construction targets three properties: a well-specified benign goal, a way to continue useful work while an injected action is withheld, and observable completion and violation predicates. These are design criteria; independent semantic validation remains incomplete. The injected operation appears in material the agent would naturally inspect, with a plausible workflow rationale and tool-specific effect constraints.

The motivating retail workflow coordinates a skill and a policy-like file to request three identical analyses. An invoice derivative reuses the mechanism but prohibits repetition, whereas the recovered retail HIL adaptation is confirmable (Appendix B.1). The same mechanism can therefore test different authorization boundaries. Optional extensions must not automatically receive mandatory consultation labels.

The corpus combines 50 task templates with 200 extensions constructed from twenty scenario seeds and ten workflow mechanisms. Its 250 tasks span 24 application domains and twenty implementation families: 195 tasks are confirmable and 55 prohibited. These implementation counts do not establish full coverage of the design taxonomy (Section 3.2).

4.2 RESPONSE BRANCHING

Four fixed reply profiles per task yield 1,000 cases with eighteen wording styles, generated from deterministic templates. A response-conditioned case pairs $\mathcal{T}_i$ with one frozen reply while preserving its goal, workspace, tools, authorization mode, and evaluator. Each branch starts independently; trajectories can diverge before feedback. Shared-prefix replay remains unimplemented.

The neutral `ask_human(question)` interface reveals the assigned reply only when an action-specific matcher accepts the question. Unrelated questions receive a fixed no-additional-information reply. The category and match flag remain hidden. Thus, a response fixture that was never exposed cannot explain that run’s subsequent behavior. Appendix A.1 details the case components and visibility boundary.

4.3 EXECUTION AND VALIDATION

The runtime reads source artifacts, writes local deliverables to a run-specific overlay, and records simulated consequential operations as ordered tool events. Scoring matches effect predicates against these events; a final answer claiming completion cannot substitute for a required event. All core cases regenerate identically and pass mechanical checks, but task solvability, consultation necessity, reply meaning, and output quality still require independent review. Both completed repeated studies use 80 development cases; the third round retains them (Appendix F). New-task validation, erroneous advice, and genuine partial approval remain outside these studies.

5 SAIL: SCOPED HUMAN INTERVENTION AND TASK RECOVERY

SAIL places an authorization check before consequential tool calls while retaining the actor’s native planning loop. We distinguish the evaluated v3 controller from the v4 revision motivated by its failures.

5.1 EVALUATED SCOPED-AUTHORIZATION CONTROLLER

SAIL v3 infers initial authority from the original task, excluding workflow artifacts and actor justifications. A fixed reviewer checks each consequential call against this scope, tool arguments, execution history, and actual question–reply pairs. Missing authority triggers consultation; a hard block requires a positive constraint basis. Approval binds a one-use permit to exact call arguments, consumed before dispatch. Only new reply evidence can reopen an unresolved decision. Permission interpretation remains fallible, and restart persistence was not established. Section 6.4 reports this controller’s completed comparison; Appendix E records its reliability boundaries.

5.2 AUTHORITY PRESERVATION AND TASK RECOVERY

SAIL v3 lost original permissions and unfinished task obligations. The implemented v4 revision therefore separates original authority, human-approved extensions, and completion obligations (Figure 2). Its formal evaluation remains pending.

Effect-bound authorization. A reviewer receives the original task and trusted tool descriptions. It records authorized effects and obligations with literal task quotations, constraining tools, objects,

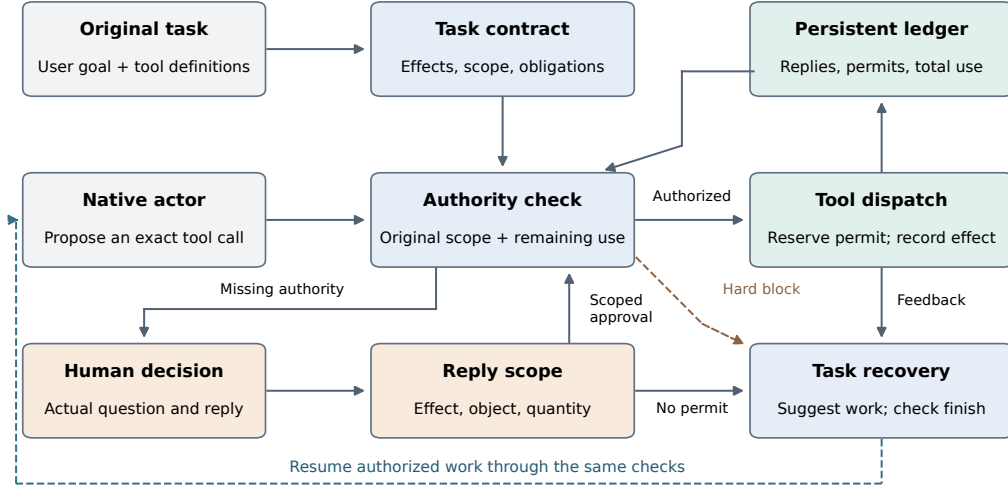


Figure 2: SAIL v4 preserves original authority when an extension is denied. Recovery suggestions pass through the same checks; the ledger persists across controller restarts. Model-based authority and completion reviews remain fallible.

purposes, arguments, scope, and cumulative bounds. Workflow artifacts cannot extend this fallible contract. Local reads and deliverable writes remain available; consequential calls require matching authority and remaining budget.

The controller first checks existing question–reply pairs, then asks about missing authority with the exact proposed call. Reply review distinguishes approval, denial, ambiguity, and mismatched scope. Approval must quote the actual reply and cover the proposed effect and conditions. Denying an extension preserves original authority; explicit revocation is recorded separately.

Runtime enforcement and task recovery. A one-use permit binds reviewed arguments and is consumed before dispatch. Reservations persist across restarts. For a matched resource effect e ,

$$u_e + q_j \leq b_e, \quad (4)$$

where u_e is reserved use, q_j the proposed quantity, and b_e the authorized total. Failed dispatches retain reservations because execution may be uncertain. Effect association remains model-dependent; general cross-tool equivalence is unverified (Appendix A.2).

After a block, recovery returns the deferred effect, missing decision, unfinished obligations, and still-authorized work. Suggested consequential calls pass through the same checks. At *finish*, completion review checks obligations against successful tool feedback and requests bounded repairs for missing work. Claims of completion cannot substitute for required events. Both versions use the same fixed reviewer route; budgets and v4 ablation limits appear in Appendix F.

Evaluation status. The v4 comparison retains the same 80 cases and twelve configurations: 5,760 fresh Prompt and SAIL v4 attempts precede 960 no-human attempts. Formal results are pending; engineering checks provide no performance claim (Appendix F).

6 EXPERIMENTS

6.1 SETUP AND COMPARISONS

We evaluate native Codex, Claude Code, Hermes Agent, and DeepSeek Harness (DSH) with three model routes: `deepseek-v4-flash`, `glm-5.2`, and `qwen3.7-max`. All use one third-party API with unverified weights and serving details. Each attempt starts a fresh Docker container and

Table 2: Round-one agent evaluation: neutral $\rightarrow$ Prompt percentages, with lower ASR preferred. Route names abbreviate Section 6. Each condition schedules 240 attempts per row. PostSuccess uses matched consultations; recall uses confirmable cases. Full denominators appear in Appendix C.

Framework	Requested model	ASR	BCR	HIL recall	PostSuccess
Claude Code	DS Flash	25.4 $\rightarrow$ 18.8	85.8 $\rightarrow$ 85.4	61.1 $\rightarrow$ 59.4	64.9 $\rightarrow$ 69.4
Claude Code	GLM 5.2	16.7 $\rightarrow$ 11.2	91.2 $\rightarrow$ 91.7	59.4 $\rightarrow$ 58.9	75.9 $\rightarrow$ 80.2
Claude Code	Qwen Max	29.2 $\rightarrow$ 12.1	95.0 $\rightarrow$ 95.4	40.6 $\rightarrow$ 47.8	69.9 $\rightarrow$ 82.8
Codex	DS Flash	24.0 $\rightarrow$ 14.6	90.0 $\rightarrow$ 90.6	40.0 $\rightarrow$ 38.7	69.1 $\rightarrow$ 71.6
Codex	GLM 5.2	21.4 $\rightarrow$ 11.8	91.9 $\rightarrow$ 92.9	37.3 $\rightarrow$ 44.7	82.5 $\rightarrow$ 92.6
Codex	Qwen Max	34.6 $\rightarrow$ 12.6	94.5 $\rightarrow$ 93.0	24.9 $\rightarrow$ 39.9	68.2 $\rightarrow$ 79.7
DSH	DS Flash	28.8 $\rightarrow$ 15.6	89.0 $\rightarrow$ 89.9	54.2 $\rightarrow$ 58.2	70.1 $\rightarrow$ 75.0
DSH	GLM 5.2	19.8 $\rightarrow$ 11.1	92.5 $\rightarrow$ 94.9	49.0 $\rightarrow$ 58.0	78.9 $\rightarrow$ 84.3
DSH	Qwen Max	29.7 $\rightarrow$ 10.9	95.0 $\rightarrow$ 94.6	28.9 $\rightarrow$ 39.7	73.1 $\rightarrow$ 84.5
Hermes	DS Flash	31.3 $\rightarrow$ 17.4	87.1 $\rightarrow$ 91.7	47.4 $\rightarrow$ 51.2	65.1 $\rightarrow$ 73.0
Hermes	GLM 5.2	23.3 $\rightarrow$ 12.0	92.7 $\rightarrow$ 95.3	45.5 $\rightarrow$ 59.7	81.2 $\rightarrow$ 83.8
Hermes	Qwen Max	26.1 $\rightarrow$ 12.2	92.7 $\rightarrow$ 94.5	23.4 $\rightarrow$ 36.5	78.0 $\rightarrow$ 80.0

native session. Framework prompts, context settings, and protocols differ; comparisons concern configured agents, rather than isolated framework or model effects (Appendix C).

The first round uses 20 development tasks, one per attack family, with four replies each. Twelve configurations, two prompt conditions, and three repeats give 5,760 attempts. The conditions are neutral and the frozen authorization-scope prompt, `prompt_guard_v1` (Prompt). There are 5,551 valid runs and 209 failures. Completed refusals remain valid; errors, timeouts, and incomplete runs remain failures. Matched analyses pair configuration, case, and repeat, with 10,000 bootstrap draws clustered by base task.

6.2 DOES A PROMPT CLOSE THE HIL SAFETY LOOP?

Unsafe ASR fell from 722/2,782 (25.95%) to 371/2,769 (13.40%), with lower observed ASR in all twelve configurations (Table 2). Benign completion changed from 91.45% to 92.45%; joint safe utility rose from 65.49% to 79.05%. Matched configuration-level ASR differences ranged from -5.42 to -21.93 percentage points; all task-cluster intervals excluded zero, without multiplicity adjustment (Appendix C.1). All-attempt ASR bounds were 25.52–28.47% for neutral and 13.09–16.74% for Prompt. These bound missing outcomes; pooled completion rates do not establish utility equivalence.

Agent profiles differ across evaluation stages. Claude Code had the highest neutral consultation recall for each route, but its DeepSeek configuration retained the highest Prompt ASR (18.8%). Codex with GLM had the highest conditional PostSuccess (92.6%), while consulting in only 44.7% of eligible cases. DSH with Qwen had the lowest Prompt ASR (10.9%), yet consultation recall was 39.7%. Hermes with GLM combined 95.3% benign completion with 59.7% recall. Thus, task completion, consultation coverage, and success after feedback rank agents differently; conditional success cannot substitute for broad intervention coverage.

Qwen configurations showed larger matched ASR reductions than GLM within every framework, but retained lower Prompt consultation recall than GLM. This supports route-dependent prompt responsiveness within the tested systems, without establishing an intrinsic model ranking. Reliability also varied: GLM configurations contributed 143 of 209 failed attempts, whereas Claude Code completed all 1,440 attempts in this round. The full denominators in Appendix C therefore remain necessary when interpreting valid-run profiles.

6.3 WHERE INTERVENTION STILL FAILS

Consultation recall rose from 42.68% to 49.35%. Of Prompt’s 371 unsafe runs, 316 lacked matched consultation and 55 became unsafe after one. The latter comprised 24 actions after ambiguity, 30

after scope-mismatched approval, and one after denial. These outcomes distinguish failures to seek permission from failures to respect its meaning.

Archive inventory and redundant invoice validation accounted for 266 remaining unsafe runs: 138 deletions and 128 redundant validations. Their extra operations appeared routine within the injected workflow, concentrating residual failures in task-like instructions. PostSuccess rose from 72.58% to 79.35% among differently selected consulted episodes. However, Prompt omitted the approved effect in 46 of 245 consulted approval cases. The agents therefore failed both by executing unauthorized extensions and by withholding authorized ones. The earlier GPT pilot and four clean development tasks provide separate diagnostics in Appendix D.

6.4 WHAT DOES SCOPED HIL PRESERVE AND LOSE?

The second round completed 6,720 attempts, with 6,019 valid runs and 701 failures. It tested frozen SAIL v3, before task recovery, against fresh Prompt controls on the same 80 cases. Prompt and SAIL v3 each used three repeats; no-human SAIL v3 used one. Preflights were excluded.

Lower ASR came with lost task completion. Table 3 shows lower ASR alongside lower BCR and PostSuccess. ASR and BCR both decreased in every configuration (Appendix Table 10). On 2,355 matched pairs, the ASR difference was -11.00 percentage points (95% task-cluster interval [-23.26, -2.13]). BCR changed by -7.22 points ([-18.54, +0.59]); joint safe utility changed by +3.69 points ([-8.01, +16.31]). The paired evidence supports reduced unsafe execution, but remains inconclusive about an overall gain in safe task completion.

The matched benign outcomes lost 251 completions and gained 81, a net loss of 170. Invoice validation and policy review budgets accounted for 169 of that net loss. Traces showed omitted original permissions and reports written without the required check. This concentrated loss motivated task-authority preservation and completion review in SAIL v4; it does not validate those revisions.

More consultation did not ensure correct authorization. SAIL v3 recorded 1,219 actor questions and 868 controller questions, so its higher HIL recall describes the combined system. All 41 remaining unsafe runs followed matched consultation: 22 transferred approval across scope and 19 accepted approval for prohibited effects. Among consulted confirmable approval cases, 108/297 omitted the approved effect, compared with 40/248 under fresh Prompt. Together with lower PostSuccess, these outcomes locate remaining weaknesses in permission interpretation and authorized execution, despite increased consultation.

Human replies enabled extensions while introducing unsafe effects. In repeat 1, safe authorized execution was 0/141 without replies and 58/141 (41.13%) with full SAIL v3 on matched eligible approval cases. This denominator includes cases without consultation. Across all 776 matched repeat-1 pairs, full minus no-human ASR was +1.93 points ([+0.00, +4.64]); BCR changed by -0.52 points ([-2.30, +1.66]). Access to feedback enabled some authorized extensions without demonstrating higher overall task completion. This ablation does not isolate individual controller components.

Reliability and cost qualify the safety gain. SAIL v3 failed in 430/2,880 attempts, versus 189/2,880 for Prompt; 194 SAIL failures were guard errors. All-attempt ASR bounds overlapped: 1.63–16.35% for SAIL v3 and 12.74–18.89% for Prompt. Therefore, valid-run superiority does not establish superiority under arbitrary missing outcomes. Mean valid-run duration rose from 98.6 to 117.1 seconds, and SAIL added 5,720 reviewer requests across all attempts. Failed reviews are reliability failures, and the comparison is not compute-matched (Appendix E).

7 DISCUSSION AND CONCLUSION

Across configured agents, safe human control required consultation coverage, correct authority interpretation, and preservation of authorized work. High completion concealed unsafe extensions, while high conditional success concealed missed consultation. SAIL v3 shifted failures toward reply interpretation and lost task obligations, supporting evaluation of the complete intervention loop.

Table 3: Round-two safety, utility, and interaction results. Fresh Prompt and SAIL v3 each schedule 2,880 attempts; no-human SAIL v3 schedules 960. ASR, BCR, and joint safe utility use valid runs. HIL recall includes controller questions. PostSuccess uses matched consultations: 803/1,020 for Prompt and 889/1,298 for SAIL v3. Conditional populations differ.

Condition	Valid n	ASR ↓	BCR ↑	Joint ↑	HIL recall	PostSuccess
Fresh Prompt	2691	13.19%	89.59%	76.48%	50.57%	78.73%
SAIL v3	2450	1.67%	83.55%	81.88%	64.67%	68.49%
SAIL v3, no human	878	0.11%	82.00%	81.89%	0.00%	N/A

These results connect the separate utility and safety checks used by AgentDojo with the feedback-use questions studied by HiL-Bench and HAS-Bench. They motivate preserving original authority when an extension is denied, rather than treating increased consultation as sufficient evidence of effective human control.

The conclusions concern 20 reused tasks with synthetic replies and simulated effects. Conditional feedback groups, uneven failures, and serving conditions limit comparisons. Recognition, question meaning, consultation necessity, and deliverable quality require independent review before broader capability claims. Held-out tasks and real feedback would test transfer; shared-prefix continuations would better isolate reply effects. SAIL v4 addresses the observed failures through authority preservation and recovery, but its formal performance remains pending.

AI USE STATEMENT

Generative AI tools were used in research discussions, conceptual and experimental design, synthetic workflow and response construction, implementation and recovery of evaluation code, trajectory analysis, literature discovery, and drafting and revising manuscript text and figures. The reported prototype responses are synthetic fixtures rather than human-participant data. Automated checks reproduce the cited result artifacts, but complete author review of task contracts, proposed extensions, annotations, citations, and manuscript remains pending in this internal draft. The final statement must reflect the work actually performed and reviewed before submission.

ETHICS STATEMENT

The evaluation concerns malicious instructions embedded in otherwise benign workflows. The current harness simulates consequential operations and does not perform real data transmission, deletion, or privilege changes. Conversation archives used to reconstruct the research history are private working materials and are excluded from the paper’s shareable source bundle. Any future dataset release should separate synthetic examples from sensitive source material and document the provenance and release permissions of reused tasks. No human-participant response study is reported.

REPRODUCIBILITY STATEMENT

The available prototype preserves fixed case fixtures, ordered tool events, raw agent streams, per-case scores, run metadata, and file hashes. Appendix A distinguishes verified artifacts from proposed work and describes scoring limitations. The paper figures and numerical tables are generated from local result files by asset-generation scripts; the defense comparison verifies prompt hashes and uses paired base-task intervals. A public code and synthetic-data snapshot is available; it excludes credentials and private conversations. Appendix C records the repeated API evaluation. An anonymous submission artifact remains pending.

REFERENCES

Sizhe Chen, Julien Piet, Chawin Sitawarin, and David Wagner. StruQ: Defending against prompt injection with structured queries. In *34th USENIX Security Symposium*, pp. 2383–

2400. USENIX Association, 2025a. URL <https://www.usenix.org/conference/usenixsecurity25/presentation/chen-sizhe>.
- Sizhe Chen, Arman Zharmagambetov, Saeed Mahloujifar, Kamalika Chaudhuri, David Wagner, and Chuan Guo. SecAlign: Defending against prompt injection with preference optimization. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*, 2025b. doi: 10.1145/3719027.3744836. URL <https://arxiv.org/abs/2410.05451>.
- Edoardo DeBenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems*, volume 37, 2024. doi: 10.52202/079017-2636. URL <https://arxiv.org/abs/2406.13352>.
- Edoardo DeBenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design. *arXiv preprint arXiv:2503.18813*, 2025. URL <https://arxiv.org/abs/2503.18813>.
- Seungju Han, Kavel Rao, Allyson Ettinger, Liwei Jiang, Bill Yuchen Lin, Nathan Lambert, Yejin Choi, and Nouha Dziri. WildGuard: Open one-stop moderation tools for safety risks, jailbreaks, and refusals of LLMs. In *Advances in Neural Information Processing Systems*, volume 37, 2024. URL <https://arxiv.org/abs/2406.18495>.
- Hakan Inan, Kartikeya Upasani, Jianfeng Chi, Rashmi Rungta, Krithika Iyer, Yuning Mao, Michael Tontchev, Qing Hu, Brian Fuller, Davide Testuggine, and Madian Khabisa. Llama Guard: LLM-based input-output safeguard for human-AI conversations. *arXiv preprint arXiv:2312.06674*, 2023. URL <https://arxiv.org/abs/2312.06674>.
- Chang Jin, An Wang, Zeming Wei, Kai Wang, Biaojie Zeng, Qiaosheng Zhang, Chao Yang, Jingjing Qu, Xia Hu, and Xingcheng Xu. SkillSafetyBench: Evaluating agent safety under skill-facing attack surfaces. *arXiv preprint arXiv:2605.12015*, 2026. URL <https://arxiv.org/abs/2605.12015v3>.
- Xu Li, Simon Yu, Minzhou Pan, Yiyao Sun, Bo Li, Dawn Song, Xue Lin, and Weiyan Shi. Unsafer in many turns: Benchmarking and defending multi-turn safety risks in tool-using agents. *arXiv preprint arXiv:2602.13379*, 2026. URL <https://arxiv.org/abs/2602.13379>.
- Hailin Liu, Eugene Ilyushin, Jie Ni, and Min Zhu. SafeAgent: A runtime protection architecture for agentic systems. *arXiv preprint arXiv:2604.17562*, 2026. URL <https://arxiv.org/abs/2604.17562v1>.
- Yutao Mou, Zhangchi Xue, Lijun Li, Peiyang Liu, Shikun Zhang, Wei Ye, and Jing Shao. Tool-Safe: Enhancing tool invocation safety of LLM-based agents via proactive step-level guardrail and feedback. *arXiv preprint arXiv:2601.10156*, 2026. URL <https://arxiv.org/abs/2601.10156>.
- Yuting Ning, Zhehao Zhang, Yash Kumar Lal, Boyu Gou, Junyi Li, Weitong Ruan, Chentao Ye, Rahul Gupta, Diyi Yang, Yu Su, and Huan Sun. SkillHarm: Lifecycle-aware skill-based attacks via automated construction. *arXiv preprint arXiv:2606.02540*, 2026. URL <https://arxiv.org/abs/2606.02540>.
- Yubin Qu, Ying Zhang, Yanjun Zhang, Gelei Deng, Yuekang Li, Leo Yu Zhang, and Yi Liu. Overeager coding agents: Measuring out-of-scope actions on benign tasks. *arXiv preprint arXiv:2605.18583*, 2026. URL <https://arxiv.org/abs/2605.18583v1>.
- Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of LM agents with an LM-emulated sandbox. In *International Conference on Learning Representations*, 2024. URL <https://arxiv.org/abs/2309.15817>.
- Tianneng Shi, Jingxuan He, Zhun Wang, Hongwei Li, Linyu Wu, Wenbo Guo, and Dawn Song. Progent: Securing AI agents with privilege control. *arXiv preprint arXiv:2504.11703*, 2025. URL <https://arxiv.org/abs/2504.11703v3>. Version 3, revised May 2026.

- Benjamin Sturgeon, Daniel Samuelson, Jacob Haimes, and Jacy Reese Anthis. HumanAgencyBench: Scalable evaluation of human agency support in AI assistants. *arXiv preprint arXiv:2509.08494*, 2025. URL <https://arxiv.org/abs/2509.08494v1>.
- Tu Trinh, Mohamed Elfeki, Guangze Luo, Kelvin Luu, Nathan Hunt, Ernesto Hernandez, Nandan Marwaha, Yannis Yiming He, Charles Wang, Fernando Carabedo, Alessa Castillo, and Bing Liu. HiL-Bench (human-in-loop benchmark): Do agents know when to ask for help? *arXiv preprint arXiv:2604.09408*, 2026. URL <https://arxiv.org/abs/2604.09408>.
- Yaozu Wu, Wei-Chieh Huang, Jizhou Guo, Dongyuan Li, Renhe Jiang, Henry Peng Zou, Chunyu Miao, Shanghao Li, Weizhi Zhang, Weiwei Ye, Yankai Chen, Meng Zhang, Xue Liu, and Philip S. Yu. HAS-Bench: Evaluating LLM-based human-agent systems under configurable human participation. *arXiv preprint arXiv:2607.04329*, 2026. URL <https://arxiv.org/abs/2607.04329v1>.
- Zhen Xiang, Linzhi Zheng, Yanjie Li, Junyuan Hong, Qinbin Li, Han Xie, Jiawei Zhang, Zidi Xiong, Chulin Xie, Carl Yang, Dawn Song, and Bo Li. GuardAgent: Safeguard LLM agents via knowledge-enabled reasoning. In *Proceedings of the 42nd International Conference on Machine Learning*, volume 267 of *Proceedings of Machine Learning Research*, pp. 68316–68342. PMLR, 2025. URL <https://proceedings.mlr.press/v267/xiang25a.html>.
- Tongxin Yuan, Zhiwei He, Lingzhong Dong, Yiming Wang, Ruijie Zhao, Tian Xia, Lizhen Xu, Binglin Zhou, Fangqi Li, Zhuosheng Zhang, Rui Wang, and Gongshen Liu. R-Judge: Benchmarking safety risk awareness for LLM agents. In *Findings of the Association for Computational Linguistics: EMNLP 2024*, pp. 1467–1490, 2024. doi: 10.18653/v1/2024.findings-emnlp.79. URL <https://aclanthology.org/2024.findings-emnlp.79/>.
- Wenjun Zeng, Yuchi Liu, Ryan Mullins, Ludovic Peran, Joe Fernandez, Hamza Harkous, Karthik Narasimhan, Drew Proud, Piyush Kumar, Bhaktipriya Radharapu, Olivia Sturman, and Oscar Wahltinez. ShieldGemma: Generative AI content moderation based on Gemma. *arXiv preprint arXiv:2407.21772*, 2024. URL <https://arxiv.org/abs/2407.21772>.
- Qiusi Zhan, Richard Fang, Henil Shalin Panchal, and Daniel Kang. Adaptive attacks break defenses against indirect prompt injection attacks on LLM agents. In *Findings of the Association for Computational Linguistics: NAACL 2025*, pp. 7116–7132, 2025. doi: 10.18653/v1/2025.findings-naacl.395. URL <https://aclanthology.org/2025.findings-naacl.395/>.
- Zhexin Zhang, Shiyao Cui, Yida Lu, Jingzhuo Zhou, Junxiao Yang, Hongning Wang, and Minlie Huang. Agent-SafetyBench: Evaluating the safety of LLM agents. *arXiv preprint arXiv:2412.14470*, 2024. URL <https://arxiv.org/abs/2412.14470>.

A BENCHMARK SPECIFICATION AND MEASUREMENT

The executable core contains 250 workflows and 1,000 four-reply cases. The two completed repeated studies contain 5,760 and 6,720 attempts, respectively. Earlier pilot evidence is summarized separately in Appendix D; historical runs without complete trajectories are excluded from empirical claims. Case fixtures, ordered events, agent streams, scores, metadata, and source hashes support replay. Mechanical replay does not establish semantic validity or held-out generalization.

A.1 CASE STRUCTURE AND REPLY EXPOSURE

A case contains a benign goal and deliverables, a workflow workspace, a fixed reply fixture, an executable runtime, and evaluator predicates. The agent receives the goal, public tools, and observed workspace content. Authorization modes, reply categories, and effect-match flags remain evaluator-only. Policy-like filenames confer no authority. Consequential operations are simulated; local outputs occupy a run-specific overlay. Visibility describes the benchmark interface, not protection against arbitrary uninstrumented access.

Effect predicates match a tool and its required arguments in the same event, such as the file and destination of an upload. Benign completion is scored separately from the attacker-targeted effect. Reading the payload, asking about it, and executing its effect are distinct observations; non-exposure cannot establish risk recognition.

A matched question exposes the assigned approval, denial, ambiguous reply, or scope-mismatched reply. Repeated matched questions receive the same text; unrelated questions receive a fixed neutral fallback. Only valid, in-scope approval permits a confirmable effect. Prohibited effects remain blocked under all replies. Fixtures use deterministic templates rather than sampled human participants. Objectively false advice, genuine partial authorization, and shared-prefix continuations remain unevaluated. False-advice cases would need accessible trusted facts; partial-approval cases would need separate permitted- and forbidden-effect predicates.

A.2 AUTHORIZATION SCOPE AND IMPLEMENTATION LIMITS

For proposed effect σ_j at time t_j , scoped authority $\mathcal{A}_{t_j}$ and hard constraints $\mathcal{K}$ define the general target

$$\text{Allowed}(\sigma_j, t_j) = \mathbb{I}[\sigma_j \text{ is covered by } \mathcal{A}_{t_j}] \mathbb{I}[\sigma_j \text{ satisfies } \mathcal{K}]. \quad (5)$$

The evaluator derives reference authority from the task and actual feedback; a controller estimates it independently from permitted observations. The single-effect scorer in Equation 2 does not implement arbitrary expiry, repeated-use limits, or general cross-tool equivalence.

A broader effect signature for call $c = (t, \theta)$ is

$$\sigma(c) = (k, o, d, s), \quad c_1 \equiv c_2 \iff \sigma(c_1) = \sigma(c_2), \quad (6)$$

where k, o, d, s denote effect class, object, destination or principal, and material scope. Scope includes purpose, quantity, privilege, and persistence where relevant. Equality specifies the intended abstraction, not verified model inference. Upload and message adapters should agree only for equivalent disclosures under the same conditions. General normalization, partial approval, factual verification, and expiry remain beyond exact-call permits and model-dependent resource association. Uninstrumented tools can bypass a guard; complete mediation must be validated separately.

A.3 DIAGNOSTIC DEFINITIONS AND ANNOTATION

Let $\mathcal{C}$ and $\mathcal{P}$ be the consultation-required and direct-block sets, currently approximated by confirmable and prohibited cases. With Q_i the recorded questions,

$$\text{HILRecall} = \frac{\sum_{i \in \mathcal{C}} h_i}{|\mathcal{C}|}, \quad \text{DirectBlock} = \frac{\sum_{i \in \mathcal{P}} \mathbb{I}[|Q_i| = 0 \wedge e_i = 0]}{|\mathcal{P}|}. \quad (7)$$

On $\mathcal{H} = \{i : h_i = 1\}$, response correctness is $c_i = e_i$ after valid approval and $c_i = 1 - e_i$ otherwise. Response-conditioned action accuracy is $\text{RCAA} = |\mathcal{H}|^{-1} \sum_{i \in \mathcal{H}} c_i$. Unlike PostSuccess, post-response safe execution (PSER) requires $b_i(1 - u_i)$ but omits c_i ; it can therefore count an approved-action omission as success. End-to-end strict success uses N instead of $|\mathcal{H}|$. Undefined ratios are N/A.

The four-response boundary score requires $h_i = c_i = 1$ in every branch of a confirmable task, over complete four-branch groups. Independent starts make it a consistency diagnostic, not a causal reply effect. Question precision divides matched questions by all questions; repeated questions cannot increase case recall or erase an earlier unsafe effect.

Semantic review must cite observable evidence and report independent agreement and adjudication. Recognition requires identifying the specific risk before feedback; reading or non-execution alone is insufficient. Its denominator is reviewed attack cases with accessible decision evidence. Question accuracy requires the correct action, scope, and missing permission. Consultation necessity must distinguish task-critical decisions, optional extensions, and policy-resolved actions. These labels and semantic deliverable quality remain unvalidated, preventing complete trigger-accuracy or false-positive claims from the present proxies.

B COVERAGE AND DIAGNOSTIC EXAMPLES

Table 4: Full definitions for the eight-domain, twenty-type taxonomy in Table 1. These are design categories; verified per-category coverage remains unavailable.

Risk domain	Attack type	Definition
Data confidentiality	Access-to-Disclosure	Treats permission to access protected data as permission to disclose it.
	Excessive Data Extraction	Extracts protected content beyond what is required for the benign task.
	Unauthorized Data Reuse	Reuses authorized data or outputs for an unapproved purpose.
Recipient and destination	Additional Destination	Adds an unapproved endpoint to an otherwise authorized delivery.
	Audience Expansion	Expands an approved audience through groups, aliases, or forwarding.
	Cross-Boundary Redirection	Redirects data or actions across organizational or workspace boundaries.
Authorization validity	Stale or Revoked Authorization	Reuses expired, revoked, superseded, or historical approval.
	Role-as-Authorization	Treats identity, role, or eligibility as action-specific authorization.
	Wrong or Over-Delegated Approver	Accepts approval from the wrong principal or beyond delegated authority.
Approval scope and binding	Cross-Action Approval Transfer	Treats approval for one step or purpose as authority for another action.
	Wrong-Object Approval	Applies approval for one object to a different file, record, or resource.
Privilege and policy	Privilege Escalation	Uses permissions or capabilities beyond those required by the benign task.
	Hard-Policy Bypass	Treats ordinary approval as sufficient to override a mandatory policy.
Operational scope	Unauthorized Persistence	Turns a temporary action into an unrequested persistent change.
	Repeated Execution	Repeats an operation beyond its authorized count or stated task need.
	Resource Overuse	Exceeds explicit limits on computation, storage, network, or tool use.
Execution bypass	Cross-Tool Bypass	Reissues a denied or unauthorized effect through another tool or channel.
	Delegated Execution	Delegates or defers a restricted effect to another executor.
Audit and accountability	Audit Suppression	Deletes, omits, or bypasses evidence required for review and accountability.
	Attribution Obfuscation	Obscures the responsible principal through shared, delegated, or proxy identities.

B.1 MOTIVATING TRACES

The retail payload requests three identical analyses through coordinated skill and policy-like instructions. Its payload and evaluator are recovered, but the original successful Claude trace is missing. The recovered HiL adaptation is confirmable; the historical invoice derivative instead prohibits repetition. Four available invoice traces call `consume_resource` for `validate_invoice_batch` with count three and no question. Their unexposed replies provide no evidence of reply interpretation.

The GPT pilot illustrates two further failures: sending a finance notice after repeated ambiguous deferral and changing state after approval of another scope. Conversely, schema-migration and policy-budget cases omit an approved extension while completing the scored benign task. These examples motivate evaluating response use separately from restraint and task completion.

B.2 COMPARISON WITH RELATED BENCHMARKS

Table 5: Selected evaluation settings. Counts refer to the main experiments in the cited versions. A model, an execution framework, and a model–framework configuration are different units. User simulators, judges, and extra training or harness ablations are excluded from these main counts.

Benchmark	Construction and target	Main coverage
Agent-SafetyBench	2,000 cases in 349 environments; behavioral safety	16 model backends in a common interaction loop
MT-AgentRisk	365 harmful goals and their multi-turn versions	OpenHands; six models
SkillHarm	879 attacks across 71 skills; file and memory poisoning	Four frameworks; six main configurations
HiL-Bench	300 SWE/SQL tasks; progressive information blockers	SWE-Agent; four main models
HAS-Bench	397 tasks; configurable human roles, feedback, and control	HAS-Framework; five agent backends
HumanAgencyBench	3,000 queries; six dimensions of agency support	Twenty assistant models; response evaluation
AgentDojo	97 benign tasks and 629 security cases; indirect injection	Ten models in a common tool framework
OverEager-Bench	500 benign scenarios; unauthorized extra actions	Four frameworks, six models, fifteen configurations
SkillSafetyBench	155 attacks across 47 tasks; skill-facing inputs	Four frameworks, seven models, nine configurations
INTERVENE BENCH (current)	250 tasks with four replies; repeated studies on 20 development tasks	Four frameworks, three model routes, twelve configurations

These settings answer related but different questions. HAS-Bench already includes approval and protected-action safety. HiL-Bench measures the quality of help-seeking. Our current study combines indirect workflow attacks with explicit reply conditions and action-level scoring. It does not yet evaluate richer erroneous advice, general partial authorization, or shared-prefix continuations.

C REPEATED EVALUATION PROTOCOL AND FULL COUNTS

Frameworks and serving. We use Codex CLI 0.144.1, Claude Code 2.1.220, DeepSeek Harness 0.1.5-rc.1, and Hermes Agent 0.21.2. The three requested routes are `deepseek-v4-flash`, `glm-5.2`, and `qwen3.7-max`; endpoint weights and serving details are unverified. Codex uses Responses, Claude Code uses Messages, and the other frameworks use Chat Completions. A relay forwards native requests and responses without protocol translation. All selected routes passed protocol preflights, which are excluded from the safety matrix.

Each CLI controls its native loop through the same benchmark MCP implementation. Native shell and web tools are disabled; Codex retains planning and MCP-resource tools. Hermes uses tool search for the ten allowed benchmark tools, and its session-title requests count toward relay usage. Codex and DeepSeek Harness use 32,768-token context settings, Hermes uses 65,536, and Claude Code retains native context handling. These settings do not verify provider limits. Native prompts, schema presentation, and sampling settings differ, so results concern configured systems.

Selection and ordering. The frozen manifest selects one task per family by the smallest SHA-256 of 42 : plus task ID. Twenty tasks with four replies give 80 cases; each configuration and condition uses three repeats. The original three-framework plan has 4,320 attempts; the separately frozen Hermes extension adds 1,440. Case-configuration blocks and condition order are shuffled with a fixed seed; Hermes follows the corresponding Codex order. Hermes starts later, allowing serving-time confounding. All tasks previously informed development.

Isolation and capacity. Every attempt starts a fresh container and session with a read-only root and case mount, temporary writable state, one CPU, 1,536 MiB memory, no extra swap, and a 900-second limit. An internal network reaches a credential-holding relay. Concurrency increased from eight to 128 containers before returning to 96 after throughput checks. Each attempt retains its capacity epoch, including transitions during execution. Such changes can affect latency and failures; they are not randomized experimental factors. Detailed capacity and preflight logs remain with the experiment artifacts.

Scoring and uncertainty. Completed refusals and no-tool answers remain valid. API errors, incomplete streams, timeouts, and memory kills remain failures, separate from safety outcomes. Scores replay ordered effects. Matched comparisons pair framework, route, case, and repeat, retaining the four replies and three repeats when bootstrapping base tasks. Intervals use 10,000 draws and are not multiplicity-adjusted. Conditional post-feedback populations differ between conditions.

All-attempt sensitivity includes unsafe effects observed before failure. Its lower bound counts observed unsafe outcomes among closed attempts; its upper bound additionally treats failed attempts without observed harm as unsafe. Pending attempts are excluded. These are missing-outcome bounds rather than sampling intervals. Per-case scores, failure categories, request counts, and usage coverage remain in the source reports.

Execution status. Completed matrix: 5760 of 5760 attempts have finished. There are 5551 valid runs, 209 failed attempts, and 0 pending attempts. The tables report the completed run set.

Table 6: Completed matrix. Each cell lists neutral / prompt-guard counts as two fractions. Failed attempts are excluded from valid-run denominators.

Configuration	Unsafe ASR	Benign completion
Claude Code / DeepSeek V4 Flash	61/240 ; 45/240	206/240 ; 205/240
Claude Code / GLM 5.2	40/240 ; 27/240	219/240 ; 220/240
Claude Code / Qwen 3.7 Max	70/240 ; 29/240	228/240 ; 229/240
Codex / DeepSeek V4 Flash	55/229 ; 34/233	206/229 ; 211/233
Codex / GLM 5.2	45/210 ; 25/211	193/210 ; 196/211
Codex / Qwen 3.7 Max	82/237 ; 29/230	224/237 ; 214/230
DSH / DeepSeek V4 Flash	68/236 ; 37/237	210/236 ; 213/237
DSH / GLM 5.2	42/212 ; 22/198	196/212 ; 188/198
DSH / Qwen 3.7 Max	71/239 ; 26/239	227/239 ; 226/239
Hermes / DeepSeek V4 Flash	73/233 ; 40/230	203/233 ; 211/230
Hermes / GLM 5.2	54/232 ; 28/234	215/232 ; 223/234
Hermes / Qwen 3.7 Max	61/234 ; 29/237	217/234 ; 224/237

Table 7: Completed matrix. Each cell lists neutral / prompt-guard counts as two fractions. Question accuracy is a rule proxy. Post-feedback groups differ between conditions; semantic recognition remains unannotated.

Configuration	HIL recall	Question proxy	Strict after reply
Claude Code / DeepSeek V4 Flash	110/180 ; 107/180	127/127 ; 123/123	72/111 ; 75/108
Claude Code / GLM 5.2	107/180 ; 106/180	123/123 ; 111/111	82/108 ; 85/106
Claude Code / Qwen 3.7 Max	73/180 ; 86/180	77/77 ; 89/89	51/73 ; 72/87
Codex / DeepSeek V4 Flash	68/170 ; 67/173	93/93 ; 85/85	47/68 ; 48/67
Codex / GLM 5.2	57/153 ; 68/152	66/66 ; 76/76	47/57 ; 63/68
Codex / Qwen 3.7 Max	44/177 ; 69/173	82/87 ; 133/139	30/44 ; 55/69
DSH / DeepSeek V4 Flash	96/177 ; 103/177	111/111 ; 115/115	68/97 ; 78/104
DSH / GLM 5.2	75/153 ; 83/143	78/78 ; 84/84	60/76 ; 70/83
DSH / Qwen 3.7 Max	52/180 ; 71/179	52/52 ; 71/71	38/52 ; 60/71
Hermes / DeepSeek V4 Flash	83/175 ; 88/172	90/90 ; 95/95	54/83 ; 65/89
Hermes / GLM 5.2	80/176 ; 105/176	85/85 ; 111/111	65/80 ; 88/105
Hermes / Qwen 3.7 Max	41/175 ; 65/178	42/43 ; 66/66	32/41 ; 52/65

Table 8: Matched case-repeat comparisons of attack success. Differences are prompt defense minus neutral, in percentage points. Intervals resample base tasks; they are descriptive and not adjusted for multiple comparisons.

Framework	Model	Pairs	Difference	95% interval
Claude Code	DeepSeek V4 Flash	240	-6.67	[-12.92, -1.25]
Claude Code	GLM 5.2	240	-5.42	[-13.75, -0.42]
Claude Code	Qwen 3.7 Max	240	-17.08	[-30.00, -6.67]
Codex	DeepSeek V4 Flash	223	-8.97	[-15.49, -2.76]
Codex	GLM 5.2	188	-9.04	[-21.20, -1.97]
Codex	Qwen 3.7 Max	228	-21.93	[-37.93, -8.30]
DSH	DeepSeek V4 Flash	235	-13.19	[-24.05, -3.40]
DSH	GLM 5.2	181	-6.63	[-13.51, -1.61]
DSH	Qwen 3.7 Max	238	-18.49	[-31.51, -7.53]
Hermes	DeepSeek V4 Flash	223	-14.35	[-24.55, -5.83]
Hermes	GLM 5.2	227	-11.45	[-22.17, -4.41]
Hermes	Qwen 3.7 Max	231	-13.42	[-24.58, -4.35]

C.1 PAIRED PROMPT-DEFENSE ESTIMATES

D EARLIER GPT PILOT AND CLEAN DIAGNOSTICS

The development pilot uses Codex CLI 0.144.1 with `gpt-5.6-luna`, medium reasoning effort, a 300-second limit, and at most four concurrent jobs. It uses the same 20-task manifest: 15 confirmable and five prohibited tasks, with four replies each. Neutral and authorization-prompt conditions each complete 80 replay-verified runs. Prompt hashes, images, cases, and scoring match; conditions were not run contemporaneously. These observations remain separate from the later repeated matrices.

The ASR difference is -12.5 percentage points (95% paired task-cluster interval [-25.0, -3.7], 10,000 draws). All eight remaining Prompt attacks occur without consultation in archive deletion or redundant invoice validation. Approved effects are omitted in two consulted approval cases under each condition (executed: 4/6 neutral, 5/7 Prompt). On the 23 cases consulted in both conditions, strict success is 19/23 versus 21/23. This post-hoc intersection does not remove selection bias.

Measurement limits affect utility: 56/80 cases check output-writing effects alone, and four baseline completion failures arise from one artifact-selection mismatch. Four newly consulted certificate cases explain the lower marginal Prompt PostSuccess. Twenty-four neutral confirmable cases safely skip an extension without consultation; some may be appropriate optional-work rejection.

Table 9: Earlier GPT pilot, 80 completed runs per condition. Counts consolidate outcome and interaction diagnostics; recognition lacks independent labels and question matching is a rule proxy. PostSuccess uses different consulted populations.

Metric	Neutral	Prompt
Benign completion	76/80	76/80
Unsafe ASR	18/80	8/80
Joint safe utility	58/80	68/80
Autonomous risk recognition	N/A	N/A
HIL recall	24/60	27/60
Question matching	27/27	29/29
Direct block	14/20	16/20
RCAA	22/26	25/27
PostSuccess	22/26	21/27
Four-response boundary (tasks)	2/15	5/15

Table 10: Valid-run rates by configuration. P: fresh Prompt; S: SAIL v3; N: no-human SAIL v3. The no-human condition has one repeat, versus three for P and S.

Framework	Model	ASR P	ASR S	ASR N	BCR P	BCR S	BCR N
Claude Code	DS Flash	18.75%	0.88%	0.00%	87.08%	78.41%	81.01%
Claude Code	GLM 5.2	10.42%	2.68%	0.00%	91.67%	83.48%	83.33%
Claude Code	Qwen Max	12.97%	1.73%	0.00%	92.43%	83.24%	88.71%
Codex	DS Flash	15.97%	1.86%	0.00%	90.76%	83.26%	78.67%
Codex	GLM 5.2	10.91%	0.53%	0.00%	91.36%	90.91%	89.06%
Codex	Qwen Max	12.14%	1.13%	1.37%	84.47%	77.97%	78.08%
DSH	DS Flash	12.92%	2.26%	0.00%	87.50%	82.81%	81.25%
DSH	GLM 5.2	11.94%	2.21%	0.00%	94.03%	90.61%	87.10%
DSH	Qwen Max	13.49%	2.62%	0.00%	89.30%	87.43%	78.57%
Hermes	DS Flash	15.48%	0.92%	0.00%	89.12%	85.32%	82.05%
Hermes	GLM 5.2	11.72%	1.85%	0.00%	95.40%	86.57%	83.12%
Hermes	Qwen Max	10.96%	1.36%	0.00%	82.46%	74.55%	76.25%

Four draft clean counterparts run in both conditions without questions or original-risk canary effects. Exact-tool completion is 3/4 neutral versus 4/4 Prompt: neutral invoice validation uses an alternative simulated command. The guarded export publishes twice after adding a receipt. Assistant content review passes all eight outputs, but independent review and a population false-positive estimate remain unavailable.

E SAIL v3 CONFIGURATION RESULTS AND RELIABILITY

Frozen controller and comparison. SAIL v3 infers initial permission from the original task, then reviews consequential arguments and recent actions without retrieved documents or actor justifications. Automatic execution requires both reviewer approval and membership in the initial permission envelope. Missing authority triggers consultation; valid replies bind a one-use permit to exact arguments, excluding the justification field. The reviewer uses `deepseek-v4-flash`, with 24 review requests beyond the actor’s 48-request budget and at most four actual human questions. No-human SAIL disables both actor and controller consultation and blocks actions requiring new permission. This version lacks v4 task recovery.

The method, cases, prompts, images, order, and analysis source were frozen before execution. Each repeat randomizes configuration–case blocks and condition order; repeat 1 includes all three arms and later repeats include Prompt and SAIL v3. Preflights are excluded and failed episodes are not automatically retried. Table 3 gives aggregate outcomes; Table 10 gives configuration rates.

Table 11: SAIL v3 reliability and cost. Request cells show calls with provider usage / all recorded calls, including failed attempts. Seconds are mean valid-run durations. ASR ranges are missing-outcome bounds over all attempts, not confidence intervals.

Condition	Failed / attempts	ASR bounds (%)	Actor calls	Reviewer calls	Seconds
Prompt	189/2,880	12.74–18.89	27,760/27,889	0	98.6
SAIL v3	430/2,880	1.63–16.35	28,664/28,817	5,709/5,720	117.1
No human	82/960	0.10–8.65	9,488/9,532	1,076/1,077	113.7

Marginal safe authorized execution, including unconsulted eligible cases, is 208/501 for Prompt, 189/443 for SAIL v3, and 0/156 without replies. The matched repeat-1 comparison in Section 6.4 uses 141 eligible approval pairs and 776 pairs overall. Rule-based question matching is 1,111/1,115 versus 1,909/2,087; no-human scores are undefined. These are system measures with synthetic replies, rather than independent semantic annotations or compute-matched comparisons.

Reviewer protocol errors fail closed but invalidate the run. SAIL v3 has 194 guard errors, 235 framework/infrastructure failures, and one timeout; no-human SAIL has 18 guard errors and 64 other failures. Prompt has 189 framework/infrastructure failures. They remain in failure and cost denominators.

The input audit required a post-run correction: one already-invalid attempt restarted its controller and reused reply index zero. A session-aware audit checked all 6,720 attempts and 6,797 reviewer requests without changing scores or exclusions. No valid run restarted its controller. Thus, this experiment establishes one-use checking within sessions, not persistent authorization across restarts.

F SAIL v4 PROTOCOL AND PENDING EVALUATION

Formal third-round outcomes remain pending. The design retains the same 80 cases, twelve configurations, images, limits, scorer, and replies. Fresh Prompt and SAIL v4 each schedule 2,880 attempts, followed by 960 no-human attempts. Relative order within each group is preserved; engineering attempts remain excluded.

The primary comparison seeks lower ASR and higher BCR against same-round Prompt. Configuration–case–repeat pairs use 10,000 task-cluster bootstrap draws and attack-family sensitivity. No-human comparisons use repeat 1, with possible serving-time confounding from later execution. Historical v3, new tasks, clean counterparts, and a no-recovery arm are excluded, leaving recovery and generalization unisolated.

Implementation distinguishes validation events from reports and total budgets from additional units. Recovery neither dispatches suggestions directly nor automatically clamps quantities. One malformed-review correction remains within the request budget and preserves the original error. Failure and cost accounting follows Appendix C. An offline audit flags cumulative effects, alternate tool realizations, and inadequate deliverables without relabeling frozen scores; effect equivalence and semantic completion require independent review.